Compliance Annotation

Sunrise Family Health Clinic

Framework: HIPAA | Compliance Level: Non-Compliant / High Risk

---

Finding 1: [VIOLATION] Improper Document Title and Missing Mandatory Header (45 CFR 164.520(b)(1)(i)) The document is titled "Privacy Policy" rather than the legally required "Notice of Privacy Practices". Furthermore, it completely omits the mandatory, verbatim header: "THIS NOTICE DESCRIBES HOW MEDICAL INFORMATION ABOUT YOU MAY BE USED AND DISCLOSED AND HOW YOU CAN GET ACCESS TO THIS INFORMATION. PLEASE REVIEW IT CAREFULLY". **References:** 45 CFR 164.520(b)(1)(i)

Finding 2: [VIOLATION] Unlawful Marketing Practices Without Authorization (45 CFR 164.508(a)(3)) The policy states the clinic may contact patients to provide information about "health-related products or services" as a standard practice. Under HIPAA, using PHI for marketing purposes—specifically if the clinic receives financial remuneration—requires an explicit, signed written authorization from the patient, which is not mentioned. **References:** 45 CFR 164.501, 45 CFR 164.508(a)(3)

Finding 3: [VIOLATION] Absence of Business Associate Agreement (BAA) Assurances (45 CFR 164.504(e)) The clinic admits to sharing PHI with third-party billing, IT support, and cloud storage providers. However, the policy fails to state that these entities are bound by Business Associate Agreements (BAAs) to safeguard information and report breaches, leaving the clinic in a state of high regulatory risk. **References:** 45 CFR 164.502(e), 45 CFR 164.504(e)

Finding 4: [VIOLATION] Failure to Inform of Breach Notification Rights (45 CFR 164.404) There is zero mention of the clinic's legal obligation to notify patients following a breach of unsecured PHI. HIPAA requires a commitment to notify affected individuals within 60 days of breach discovery, including specific details on the incident and mitigation steps. **References:** 45 CFR 164.404

Finding 5: [VIOLATION] Omission of Core Patient Rights (45 CFR 164.522 - 164.528) While access and amendment are mentioned, the policy omits four primary mandatory rights: the Right to an Accounting of Disclosures , the Right to Request Restrictions (including the mandatory self-pay restriction) , the Right to Confidential Communications , and the Right to a Paper Copy of the notice. **References:** 45 CFR 164.522, 164.528

Finding 6: [VIOLATION] Deficient Access Modalities (45 CFR 164.524) The policy fails to specify that the clinic must fulfill record requests within 30 days. It also fails to inform patients of their right to receive their medical records in an electronic format if they so choose. **References:** 45 CFR 164.524

Finding 7: [VIOLATION] Missing Complaint Procedure and Non-Retaliation (45 CFR 164.520(b)(1)(vi)) The clinic only directs concerns to its own office manager. It fails to inform patients of their right to file a formal complaint with the Secretary of the U.S. Department of Health and Human Services (HHS) and provides no mandatory statement that the clinic will not retaliate for filing a complaint. **References:** 45 CFR 164.520(b)(1)(vi)

Finding 8: [VIOLATION] Failure to Apply Minimum Necessary Standard (45 CFR 164.502(b)) The policy describes various disclosures to staff and third parties but never mentions the "Minimum Necessary" standard. The clinic is required to make reasonable efforts to limit PHI use and disclosure to only the amount needed to accomplish the intended purpose. **References:** 45 CFR 164.502(b), 45 CFR 164.514(d)

Finding 9: [VIOLATION] Improper Policy Change and Notification (45 CFR 164.520(b)(1)(v)) Posting changes only in the "office waiting room" is insufficient. HIPAA requires the entity to make the revised notice available upon request and prominently post the change on its website if one is maintained. **References:** 45 CFR 164.520(b)(1)(v)

Finding 10: [VIOLATION] Absence of Personal Representative Provisions (45 CFR 164.502(g)) The policy fails to acknowledge that a legal guardian or person with medical power of attorney may exercise the patient's rights on their behalf, a critical requirement for pediatric or geriatric care settings. **References:** 45 CFR 164.502(g)

Finding 11: [CONCERN] Highly Deficient Security Safeguards (45 CFR 164.312) "Password-protected computers" and "locked cabinets" represent extremely dated security standards. The policy fails to mention modern technical safeguards such as encryption (at rest and in transit), audit controls, or the performance of mandatory periodic risk analyses. **References:** 45 CFR 164.306, 164.312